

Consolidated Findings Register

Every finding raised against EVA AI to date, from three independent sources — hands-on manual testing, the automated end-to-end bench, and the read-only source review — deduplicated into one list with severity, evidence, a proposed fix shape and the regression test that will pin each one.

Compiled 27 July 2026 · Build under test: β 0.8.4 at commit `beca6ff` on DGX Spark · Companion to the Codebase & Spark Appliance Plan v2.0 · Each entry is traceable to its source report.

31

distinct findings, deduplicated across all three sources

4

release blockers — all legal or claim-honesty, none technical

15

major — degrade a shipped feature or a review posture

12

minor — usability, correctness and hygiene

4 blockers

15 major

12 minor

The three sources

SET	COUNT	METHOD
MF-1...12	12	Manual QA. Hands-on operator testing over 24–25 July, Safari and Chrome on macOS against the Spark install, including AI-driven exploratory browser sessions.
B-1...6	6	Automated bench. Wave-1 end-to-end run (nine channels, 2.07 h, frame-exact ground truth), Feature Pack 1 and the Part A experiment, all at shipped default settings.
R-1...13	13	Source review. Seven-part read-only recon of the checkout at <code>beca6ff</code> , 24 July — inventory, architecture, data flow, agent, dependencies, development practice, synthesis.

Deduplication

Three manual findings originated in the bench and are filed once, under their MF number, with the bench identifier retained: **MF-8** ← bench F-1, **MF-11** ← bench F-5, **MF-12** ← bench F-6. Where a manual finding confirms a source-review prediction, both entries stand and cross-reference each other — the prediction and its field confirmation are separately useful.

How to read an entry

Each finding carries what a developer needs to reproduce and close it: where it lives, how it was seen, what happened against what should have happened, a proposed fix shape (a suggestion, not a prescription), and the automated check that will keep it closed.

Severity means
Blocker — cannot ship publicly with this open.
Major — a shipped feature does not do what a customer would reasonably expect, or a review posture is materially weaker than claimed.
Minor — usability, correctness or hygiene; annoying, not damaging.

Two things worth saying up front
First, the blockers are all *legal or documentation* items — a licence file, a model acceptable-use confirmation, a secure default, and correcting a compliance claim. None of them is a defect in the engineering.
Second, the heaviest cluster of major findings sits in **defaults and policy**, not in code correctness: shipped thresholds that match everything, one severity for every alert, and settings that do not reach a running session. That is the pattern this register is really reporting.

All 31 findings on one page

Sorted by severity, then by source. The right-hand column is the first decision each item needs — most are engineering, but eight are product decisions that only you can make, marked **DECISION**.

ID	SEV	AREA	ONE LINE	FIRST DECISION NEEDED
R-1	BLOCKER	Legal	No LICENCE or NOTICE file — recipients have no legal grant	DECISION which licence
R-2	BLOCKER	Legal	Model acceptable-use for surveillance unconfirmed in writing	DECISION legal owner
R-3	BLOCKER	Security	Auth off by default; agent gateway bypassed entirely when off	DECISION flip default or mandate gate
R-4	BLOCKER	Compliance	Audit hash chain and tool ledger are schema-only, never populated	DECISION build or correct wording
B-1	MAJOR	Detection	53% recall on staged fights — half of real events stay silent	Threshold / prompt tuning
B-2	MAJOR	Alert policy	Every alert emitted at HIGH; 9.3 alerts/hour from one cyclist	DECISION severity policy owner
B-3	MAJOR	Data integrity	47 dropped batches in 2.07 h at nine channels, no gap marker	Confirm benign or not
B-5	MAJOR	Performance	Vision throughput declines over hours (~109 → ~69 per hour)	Engineering investigation
MF-1	MAJOR	Web UI / auth	Focus steals from password field; password lands in plaintext box	Frontend fix
MF-9	MAJOR	Probes	Default probe floor matches everything; CLIP keys on colour	DECISION default floor strategy
MF-10	MAJOR	Deployment	Four credentials plaintext in env file; Evo account is admin	Deployment engineering
MF-11	MAJOR	Probes ↔ VLM	Enabling probes suppresses that channel's marginal-event alerts	Engineering investigation
MF-12	MAJOR	Config	Saved settings never reach a running capture session	Engineering fix
R-5	MAJOR	Security	Global skills dir is a cross-tenant prompt-injection path	DECISION is it multi-tenant?
R-6	MAJOR	Process	No CI — suite and drift gate run only when someone remembers	Engineering
R-7	MAJOR	Test coverage	16,500-line browser UI has zero tests and no harness	Engineering
R-8	MAJOR	Data integrity	Durable inference queue off by default — mechanism behind B-3	DECISION on by default?
R-9	MAJOR	Scale	~110 threads in one process at 50 channels, never load-tested	Run the soak
R-10	MAJOR	Ops	Retention only on write; cap path orphans images; no disk guard	Engineering
MF-2	MINOR	UI / connector	Disabled Evo channels persist in UI; Reload doesn't refresh	Answer either-way question
MF-3	MINOR	Deployment	Self-signed TLS interstitial greets every operator	DECISION certificate story
MF-4	MINOR	Web UI / auth	No show-password toggle on the login form	Frontend fix
MF-5	MINOR	Web UI	Settings tab chips highlight but don't navigate	Frontend fix
MF-6	MINOR	IAM / audit	Sessions record 127.0.0.1 — the proxy, not the operator	Engineering fix
MF-7	MINOR	Web UI / auth	Login never triggers the browser's save-password prompt	Frontend fix
MF-8	MINOR	IAM / roles	"Operator" role cannot start or stop capture; bundles illegible	DECISION move or rename
B-4	MINOR	Coverage gap	Evo bookmark-write permission unverified — blocked by MF-12	Retest after MF-12
B-6	MINOR	Probes	Probe pipeline indexes zero frames on an image-mode channel	Confirm intended
R-11	MINOR	Air-gap	Google Fonts import and unguarded loaders break offline claim	Engineering, ½ day
R-12	MINOR	Docs	AI orientation file describes the predecessor product	Engineering, ½ day
R-13	MINOR	Continuity	Bus factor one; rationale lives outside the repository	Ongoing mitigation

Section A · Manual QA findings — MF-1 ... MF-12

Found by hand between 24 and 25 July 2026 on `β 0.8.4 @ beca6ff`, running on the DGX Spark, driven from Safari and Chrome on macOS. Three entries (MF-8, MF-11, MF-12) originated in the automated bench and are filed here with their bench identifier retained.

MF-1 Login: focus steals from the password field during re-login after session expiry

MAJOR

Area Web UI / auth (login form, `app.js`) · Seen Safari on macOS → EVA on Spark over LAN · Date 2026-07-24 · Other browsers not yet checked — a Chrome/Firefox pass would establish whether this is Safari-specific

REPRO	Be signed in and let the session expire (the login screen reappears with "Session expired. Sign in again." and the username prefilled). Click into the password field and start typing. Mid-typing, focus jumps by itself back to the username field — repeatedly.
ACTUAL	Keystrokes continue into the username field, so typed password characters land in the visible plaintext username box — a shoulder-surf and screen-share exposure on top of a confusing failed login. The only way to sign in was to type username and password together into the Username field, then cut and paste the password portion across.
EXPECTED	Focus stays where the user put it; autofocus fires at most once, when the login view first renders.
HYPOTHESIS	The expired-session state update or status polling re-renders the login view and re-runs an autofocus on the username input. Any re-render → <code>focus()</code> pattern will steal focus repeatedly.
FIX SHAPE	Guard the autofocus so it runs only on first mount of the login view, or only when neither field holds user content or focus.
REGRESSION	Playwright spec — trigger an expired-session login, type into the password field with a delay spanning a poll cycle, assert focus and field contents. Run on WebKit as well as Chromium, since the observation is from Safari.

MF-2 Disabled Evo channels stay listed in the EVA UI, and Reload does not refresh them

MINOR

Area Web UI + Evo connector (channel inventory) · Seen Safari on macOS, Evo Server with all channels disabled in Evo Console · Date 2026-07-24

REPRO	Disable all channels on the Evo Server. In the EVA UI, open the channel selector — the old channels are still listed and selectable. Press RELOAD : the list is unchanged and the selected channel shows "VIDEO UNAVAILABLE" (correct — it is disabled). Note that the summaries engine still reports RUNNING: BATCH 12 · 5S for that unavailable channel.
EXPECTED	Reload re-fetches the channel list from Evo and drops — or visibly marks as disabled or offline — channels that are no longer active.
TWO QUESTIONS	Either answer is itself a finding. (a) Does Evo's <code>getChannels</code> still return disabled channels, meaning EVA should filter or badge them — or does EVA cache the inventory so that Reload is misleading? (b) Do capture sessions and summary workers keep running against disabled channels, burning snapshot polls, vision budget and error logs? The RUNNING status suggests the pipeline never notices the channel died; if so this upgrades to a resource and correctness issue, and connects to the source review's finding that a disconnected source also stalls retention and cleanup.
REGRESSION	Bench drill — disable one Evo channel mid-capture; assert EVA marks it offline within N seconds, stops spending vision budget on it, and that Reload reflects the change; re-enable and assert recovery. Fully scriptable with the test feed and the service account.

MF-3 Browser privacy-error interstitial on the EVA UI (self-signed TLS)

MINOR

Area Deployment / TLS front end (nginx) · Seen Chrome on macOS → `https://192.168.1.28`; Safari shows equivalents · Date 2026-07-25 · minor in the lab, a product-experience issue at release

ACTUAL	Chrome shows a full-page privacy-error interstitial with "Not Secure" and a struck-through <code>https</code> — the nginx front end serves an untrusted self-signed certificate.
WHY IT MATTERS	Every fresh operator on every fresh machine meets a frightening security warning <i>on a security product</i> before they meet the product. It trains operators to click through TLS warnings — precisely the habit a surveillance vendor should not cultivate. And some managed Chrome policies block self-signed sites outright with no "Proceed" option, which would make the UI unreachable.
FIX SHAPE	A documented certificate path in the installer — customer-provided certificate, enterprise CA import, or a generated site-local CA whose root the installer exports for IT to distribute. At minimum the install guide needs a TLS certificate section; the source review found no such guidance anywhere in the docs tree.
REGRESSION	Playwright runs against the lab instance should assert the certificate story explicitly. <code>ignoreHTTPSErrors: true</code> is a documented lab-only concession, flagged in the harness config so it never leaks into a "we tested TLS" claim.

MF-4 Login: no show-password toggle on the password field

MINOR

Area Web UI / auth (login form) · Seen Chrome and Safari on macOS · Date 2026-07-25 · Cluster MF-1, MF-4 and MF-7 are one login-form ticket

ACTUAL	The password field offers no reveal toggle. With the long passwords the deployment gate encourages — install-time weak-password checks push towards 32 characters and above — typos are invisible and every failure costs a full re-type. Compounds badly with MF-1: the operator cannot even see what ended up where.
EXPECTED	A standard eye icon toggling visibility, with autocomplete="current-password" semantics preserved so password managers keep working.
FIX SHAPE	Small login-form change in app.js and the template. No backend impact.
REGRESSION	Playwright spec — the toggle reveals and hides the typed value, and the field keeps type=password by default.

MF-5 Settings dialog: tab chips do not navigate to their section

MINOR

Area Web UI / Settings dialog · Seen Chrome on macOS, during an AI-driven exploratory session · Date 2026-07-25

REPRO	Open Settings (gear) and click the USERS tab chip. The chip highlights as active but the content pane stays where it was — initially Server Configuration.
ACTUAL	Active-tab state and displayed content disagree. The dialog body is one long scroll of every section, so reaching Users takes roughly 25 wheel-scrolls past Server, Search, Models, Advanced and Luxriot — with the USERS chip lit the entire way. The Users section is effectively hidden below several screens of unrelated configuration.
EXPECTED	Clicking a tab either filters to that section or scrolls it into view.
REGRESSION	Playwright — click each settings tab and assert its section heading is in the viewport.

MF-6 Sessions list records the client IP as 127.0.0.1 — the proxy, not the operator

MINOR

Area IAM / sessions, and likely audit events · Seen EVA behind its own nginx TLS front end — the standard deployment shape · Date 2026-07-25 · minor now, audit-relevant at release

ACTUAL	Settings → Users → Sessions shows both active sessions at IP 127.0.0.1 — the nginx loopback address, not the operator workstation, which in this case was a Mac elsewhere on the LAN.
WHY IT MATTERS	Session inventory and any IP-based audit forensics cannot distinguish operator workstations, so "who signed in from where" is unanswerable — on a product whose audit story is a selling point. Every deployment has nginx in front, so every deployment has the same blindness.
FIX SHAPE	Honour X-Forwarded-For / X-Real-IP from the local nginx only, via a trusted-proxy list, and record the forwarded address in sessions and in the audit actor context. The nginx configuration is already installer-controlled.
REGRESSION	Integration test — sign in through the nginx front end and assert the session row records the true client IP, and that a spoofed X-Forwarded-For from a non-proxy source is ignored.

MF-7 Login form never triggers the browser's save-password prompt

MINOR

Area Web UI / auth (login form) · Seen Safari and Chrome on macOS — neither offers to save credentials on a successful login · Date 2026-07-25

ACTUAL	Signing in never prompts the browser or password manager to save the login, unlike any ordinary website. Operators must retype or externally store passwords every session — which in practice pushes people towards weak passwords or sticky notes, and makes the frequent session expiries behind MF-1 more painful than they need to be.
HYPOTHESIS	The login is a JavaScript fetch without real <form> submission semantics. Credential managers key on a form containing autocomplete="username" and autocomplete="current-password" inputs plus a submit-like event followed by a navigation or DOM change; if any of those is missing, no prompt appears.
FIX SHAPE	Wrap the fields in a proper form (intercepting submit in JavaScript is fine), correct the autocomplete attributes, and ensure a visible post-login state change. Optionally use the Credential Management API. Pure frontend, no backend impact.
REGRESSION	The browser chrome itself is hard to assert, so assert the DOM contract that triggers it — form element present, both autocomplete attributes correct, submit event fired on sign-in. Covers Chromium and WebKit.

MF-8 Role model: the "operator" role cannot operate capture

MINOR

Area IAM / role bundles · Origin automated bench, Wave-1 finding **F-1** — a user holding `operator + viewer` got 403 on `/luxriot/start_capture` · Date 2026-07-25 · legibility issue, needs a product decision

ACTUAL	<code>operator + viewer</code> grants <code>agent:use</code> , <code>bookmarks:create</code> , <code>detections:view</code> , <code>probes:run</code> , <code>reports:view</code> , <code>streams:view</code> — nothing in the capture-control class. Starting and stopping channel capture, the most operator-sounding action in the product, requires the engineer role.
WHY IT MATTERS	Role names set expectations, and every integrator will make the same wrong guess we did. The UI also offers only four fixed bundles, with no per-permission grant and no way to see what a bundle contains before assigning it — the granted set only becomes visible after a denial, or through the API.
FIX SHAPE	A product decision: either move <code>CAPTURE_MANAGE</code> into <code>operator</code> , or rename the bundles to match their contents. Either way, show each role's permission list in the Users UI at assignment time, as a tooltip or an expandable.
REGRESSION	The Wave-3 permission-matrix suite pins whatever bundle-to-permission mapping is decided, so future drift is caught automatically.

MF-9 Default probe threshold is non-discriminative; CLIP keys on colour, not objects

MAJOR

Area Probes / CLIP matching defaults · Evidence bench Feature Pack 1, default `pos_floor` 0.2, CLIP VIT-B/32, 18 probes across 9 channels · Date 2026-07-25 · major for the probes feature at default settings

ACTUAL	At the shipped threshold, both test probes — "orange traffic cones" and "black garbage bag / skip bag" — hit on 100% of polls on every video channel , including the synthetic timecode channel, which is a hard negative for both concepts. Nine false-positive channel-pairs.
WORSE	The two concepts differ in separability. Skip-bag becomes clean at a floor of about 0.27, but cones cannot be separated at any floor : the timecode channel's orange colour bars score 0.250 while the real cones scene scores 0.229. CLIP is matching the colour, not the object — the run-directory thumbnails make this vivid.
WHY IT MATTERS	Through the default-settings lens: an out-of-the-box customer creating their first probe gets a firehose of matches on everything, and the feature appears broken or permanently on. Because separability differs per concept, no single global floor fixes it.
FIX SHAPE	Product decisions. Raise or auto-calibrate the default floor — for example, calibrate per-probe against a few negative frames at creation time. Consider text-negative prompts ("orange colour bars", "test pattern") in scoring. Document that concrete-object probes need tuning. Possibly surface the score distribution in the UI so users can set floors visually.
REGRESSION	The bench probe suite now scores separability per concept against ground-truth channels; any change to floors, model or scoring re-measures in about 30 minutes.

MF-10 Service credentials stored in plaintext in the environment file

MAJOR

Area Deployment / secret handling · Seen production-style 0.8.4 install on the Spark · Date 2026-07-25 · major for a security product's review posture — standard practice, weak posture

ACTUAL	<code>/etc/eva-ai/eva-ai.env</code> holds service credentials as plain text, verified directly. The file is root-gated, which is the standard env-file pattern, but anyone or anything with root — or a filesystem backup of <code>/etc</code> — holds the keys to the video system. Compounding it, the service account currently holds administrator privilege on Evo.
SCOPE	Enumerated names-only on 25 July: exactly four secret-bearing values — the Evo service password plus three PostgreSQL connection strings (runtime, audit and worker, each embedding its role's password; that three-way role separation is itself good design). Notably <i>absent</i> : no admin token is set, and no model-endpoint API keys, since the local model servers run keyless. The secret surface is smaller than the configuration reference suggests, which makes sealing it cheap.
ALREADY RIGHT	The settings and environment API endpoint masks secret values (there is a named test for it), runtime JavaScript is guarded against embedding video-system credentials, and session and CSRF tokens are stored hashed in PostgreSQL. The gap is at-rest handling of <i>service</i> secrets, not leakage through the application surface.
FIX LADDER	1. Minimum — the installer enforces <code>0600 root:root</code> on the env file, documents it, and preflight verifies it. 2. Better — move the four values to systemd <code>LoadCredential=</code> or the credential store, native on the target OS with no new dependencies. 3. Document a rotation procedure; today rotating the Evo account means hand-editing this file and restarting, and nothing says so. 4. Do not claim "encrypted secret storage" anywhere until one of these ships.
REGRESSION	Predeploy acceptance asserts env-file permissions; the upgrade-and-rollback drill asserts secrets survive rotation and upgrade.

Action outstanding: the Evo service password transited chat and shell history during the 25 July work. **Rotate it before this system faces any non-lab network.** Lab context acknowledged — fully closed environment, synthetic footage only; the finding is about the shipped deployment pattern, not today's lab risk.

MF-11 Enabling CLIP probes suppresses VLM alerting on marginal events

MAJOR

Area Probes ↔ capture / VLM pipeline interaction · **Origin** automated bench, finding **F-5**; 9 channels, 18 probes · **Date** 2026-07-25 · major — a monitoring feature silently degrades the alerting feature

ACTUAL	The bicycle channel — a soft, marginal event — alerted roughly every cycle at baseline. Within about one minute of creating probes its alerts stopped entirely (0 of 7 cycles). Within about 2.3 minutes of disabling all probes they resumed (2 of 3 cycles; misses are normal for a marginal event). Both transitions align with probe state changes, which makes coincidence untenable.
MECHANISM	Unconfirmed. The strong event (the fight channel) kept alerting throughout, so the plausible mechanism is frame-budget dilution hitting marginal events hardest — probes competing for frames and attention — rather than a hard stall. One more on/off replication would make this airtight.
WHY IT MATTERS	A customer who adds probes to a channel unknowingly lowers that channel's alert sensitivity. Two shipped features fight each other, with no warning, at default settings.
FIX SHAPE	Engineering investigation of the shared budget — apex and attention frame allocation versus probe sampling. At minimum, document the interaction; ideally isolate probe sampling from the summary and alert path, or scale the budgets independently.
REGRESSION	The bench protocol is now a repeatable drill: measure baseline alert rate → enable probes → assert the alert rate is unchanged. Belongs in the nightly set once fixed.

Relevant to 0.8.5. The release rebuilds exactly this area — a per-channel L0 accumulator with activity-sensitive admission, an attention coordinator with explicit coverage debt, and probe signals carried as a sidecar rather than competing inline. Whether that resolves the interference or merely relocates it is worth an explicit answer, because the fix and the finding landed in the same week.

MF-12 Settings changes do not propagate to running capture sessions

MAJOR

Area Configuration propagation / capture session lifecycle · **Origin** automated bench, finding **F-6**; Part A experiment, 45-minute window · **Date** 2026-07-25 · major — a saved setting silently has no effect

ACTUAL	Auto-bookmarks was switched on and saved, and the settings API read back <code>true</code> throughout the window — yet 0 of 12 qualifying alerts produced a bookmark (fight channel 0/5, bicycle channel 0/7). Session logs show every one of those alerts carrying <code>delivery_status: "bookmark_disabled"</code> , with <code>bookmarks_sent</code> stuck at 0. An authenticated read against Evo confirmed zero bookmarks stored — EVA never attempted a write.
ROOT CAUSE	A running capture session reads the auto-bookmark setting at session start and caches it. Changing the setting while capture is running has no effect until the session restarts.
WHY IT MATTERS	A customer enables auto-bookmarks in the UI, the setting saves and reads back as on, and nothing happens — no error, no hint that a capture restart is required. The feature appears broken. This is the classic "setting saved ≠ setting applied" trap, and here it silently disables the product's only push-to-operator alerting path.
KNOCK-ON	It leaves B-4 untested — whether the admin-scoped service account actually holds Evo bookmark-write permission — because EVA never reached Evo. And it means any settings-driven test must account for capture-session caching.
FIX SHAPE	Either propagate the setting to live sessions (re-read per batch, or push configuration changes to running sessions) or, at minimum, surface in the UI that capture must be restarted for the setting to take effect — and expose the effective session-cached value as distinct from the saved value.
REGRESSION	The rerun protocol (enable → restart capture → measure) becomes a bench test. A stronger version asserts that toggling any live-relevant setting either applies within N seconds or the UI warns that a restart is needed. The bench operator account now holds <code>capture:manage</code> so the bench can perform the restart itself.

Pattern across MF-9, MF-11 and MF-12

None of these three is a crash, an exception or a failed test. Each is a case where the product does something reasonable-looking and reports success while delivering nothing — a probe that matches everything, a probe that silences alerts, a setting that saves but never applies. They are invisible to unit tests by construction and only appear when the system is driven end to end against known ground truth. That is the argument for the bench, stated as three findings.

Section B · Automated bench findings — B-1 ... B-6

From the Wave-1 end-to-end run (2026-07-25, nine channels, 2.07 h, frame-exact ground truth), Feature Pack 1 and the Part A experiment — all at shipped default settings, so these describe the out-of-the-box customer experience rather than a tuned configuration. Bench findings F-1, F-5 and F-6 are filed above as MF-8, MF-11 and MF-12.

BASELINE METRICS — THE REFERENCE NUMBERS EVERYTHING ELSE IS MEASURED AGAINST

METRIC	MEASURED	READING
Fight recall (channel 1)	10/19 = 53%	Roughly half of staged fights raised an alert
Alert latency	median 50 s · 7–97 s	Wide spread; the tail matters for an operator
Dance false-alarm rate (channel 2)	0/17 = 0%	Energetic motion never misread as violence
False positives, quiet + background	0	Empty corridor, crane and garden scenes all clean
Timestamp error (channel 5, optical)	0.198 s median	Excellent — forensic timeline is trustworthy
End-to-end latency (channel 9)	0.5 s	Excellent
Coverage	102–116 /channel-hour	Evenly distributed across all nine channels
Authorisation failures	0	No permission surprises during the run

B-1 Detection recall at default settings is 53% — with zero false positives

MAJOR

Area Detection policy / VLM alert thresholds · Evidence Wave-1 run, 19 staged fight cycles with frame-exact ground truth, 90 s tolerance

ACTUAL	10 of 19 staged fight cycles alerted. In the same run, zero false positives on quiet and background channels and zero dance cycles misread as violence.
READING	The error is one-sided. A system that hallucinated violence would have failed differently; this one perceives correctly and decides too conservatively. That points at thresholds, prompt wording and the alert-emission policy rather than at model capability.
CORROBORATION	The Part A experiment, run with probes disabled, reached 5 of 7 — the best figure recorded — which is independently consistent with MF-11.
FIX SHAPE	Threshold and prompt tuning as a labelled experiment series, then freeze a calibrated profile. Must be re-baselined on 0.8.5 regardless, since the new batching contract changes frame admission.
REGRESSION	The Wave-1 scoring harness re-measures recall, false-alarm rate and latency in about two hours against the same corpus. Any tuning change is measurable the same day.

B-2 Every alert is emitted at HIGH severity — 9.3 alerts per hour from one cyclist

MAJOR

Area Alert severity policy · Evidence Wave-1 bicycle channel — 18 cycles, 21 alerts, every one severity: high; Part A measured the sustained rate

ACTUAL	The bicycle channel — a person cycling past, entirely benign — produced an alert on every cycle and sometimes twice, all at HIGH severity. The sustained rate measured 9.3 alerts per hour from that one subject. The actual fights, when they alerted, arrived at the same severity as the cyclist.
WHY IT MATTERS	An operator learns within one shift that HIGH means nothing, which is the standard path to a monitoring product being ignored. Severity is also what a customer's escalation policy keys on, so a single-valued severity makes the product unintegratable into any tiered response process.
FIX SHAPE	A product decision with no current owner: what distinguishes info from low, normal, high and critical, and does the vision model assign it or does a policy layer map it? The severity map exists in configuration and is currently an identity mapping.
REGRESSION	The bench asserts a severity distribution against ground-truth event classes, so a policy change is measurable rather than argued about.

0.8.5 gives this an instrument, not a fix. Operator false-positive annotation — five reasons, per-operator upsert, provenance, Markdown and XML export — creates the feedback data a calibration effort needs. The severity policy itself is untouched by the release.

B-3 Dropped vision batches on every channel at only nine channels

MAJOR

Area Data integrity / admission gate · Evidence Wave-1 coverage table, all nine channels over 2.07 h · Predicted by R-8 in the source review

ACTUAL	Across nine channels: 47 dropped batches and 564 dropped frames , every channel non-zero — 2 to 10 dropped batches and 24 to 120 dropped frames each. Frozen-frame drops were zero throughout, so this is not a source-side artefact.
WHY IT MATTERS	The source review documented this exact path: with the durable inference queue off — the default — an admission-gate timeout destroys a summary batch permanently and leaves <i>no coverage-gap marker</i> . If that is what these counters represent, the evidence record has undisclosed holes. The review expected this at 50 channels; it is visible at nine.
THE QUESTION	The most consequential question in this register: are these counters benign — coalescing, deliberate shedding, frames the pipeline chose not to use — or true evidence gaps? The answer decides whether the durable queue must ship on by default and whether a coverage-gap row is a release requirement.
FIX SHAPE	If gaps are real: enable the shipped durable inference queue in production, and emit an explicit coverage-gap row whenever a batch dies so the hole is visible rather than silent. Either way, document what each counter means.
REGRESSION	Drop-counter observability is already a per-release check. Promote it to an assertion: the bench fails a run where dropped batches exceed an agreed floor, and asserts that any drop produced a corresponding gap marker.

Possibly touched by 0.8.5. Migration 20260726_0008 adds scheduler decisions, attention episodes and evidence links as durable rows, and the readiness endpoint now exposes queue, drop and failure counters. If a dropped batch now leaves a durable trace, this finding is partly closed by the release — that needs confirming rather than assuming.

B-4 Evo bookmark-write permission remains unverified — a coverage gap, not a defect

MINOR

Area Evo connector / permissions · Origin bench finding F-2 · Blocked by MF-12

STATUS	The intended test — does the service account actually hold bookmark-write permission on Evo? — could not run, because MF-12 meant EVA never attempted a write. The one write path the product needs against the video system is therefore still unproven end to end.
WHY IT MATTERS	Creating bookmarks is the <i>only</i> write EVA makes to Evo, and it is the basis of the minimal-permission set proposed to replace the current administrator-level service account. Until it is exercised, the least-privilege scope-down cannot be validated.
REGRESSION	Retest immediately after MF-12: enable auto-bookmarks, restart capture, assert bookmarks appear in Evo with correct title, description, severity and colour, and measure delivery latency.

B-5 Vision summary throughput declines system-wide over hours of continuous capture

MAJOR

Area Performance / long-run behaviour · Evidence observation O-3, measured after probes were disabled — 17-minute sample, noisy but beyond noise · Status open observation, not yet a confirmed defect

ACTUAL	Summary throughput fell measurably over hours of continuous capture — one channel from about 108.8 to 69.1 per hour, another from 112.5 to 79.4. The decline is system-wide rather than confined to probed channels, and <i>worsening</i> rather than settling at a plateau.
CANDIDATES	Rollup workload accumulating on the shared GPU as the 15-minute, hourly and multi-hour layers all begin firing; archive and database growth in the write path; disk behaviour. None confirmed.
WHY IT MATTERS	A slow decline is invisible in any instantaneous reading, including a green readiness check — exactly the failure mode a 72-hour soak exists to find, and what a guard-rail monitor must trend rather than sample. It also threatens any published channel ceiling, since the ceiling would be measured in the first hour.
FIX SHAPE	First establish it properly — the per-hour throughput timeline is reconstructable retroactively from summary timestamps, needing no live capture. Then attribute it, then decide whether it is bounded.
REGRESSION	Add a throughput-over-time trend to the soak report and to the guard-rail monitor; assert that end-of-soak throughput stays within an agreed fraction of the first-hour figure.

0.8.5 raises the stakes here. The audit layer moves from six to eight hours and a durable telemetry writer joins the same single process and the same GPU. Both add background work to the system that is already observed slowing down. Worth measuring before and after the upgrade.

B-6 Probe pipeline indexes zero frames on an image-mode channel

MINOR

Area Probes / channel source types · Evidence observation O-2, channel 9 (clean negative — reported "no data" rather than "no match")	
ACTUAL	On an image-mode channel the probe pipeline indexed no frames at all, so the channel returned "no data" rather than a genuine negative result.
WHY IT MATTERS	Small, but a probe silently covers fewer channels than the operator believes. "No data" and "no match" are different answers and should not look alike in the UI. It also affects the bench: a channel that indexes nothing cannot serve as a hard negative.
FIX SHAPE	Confirm whether this is intended (image-mode channels are out of probe scope by design) and, if so, say so in the UI. If not, index them.
REGRESSION	The probe suite asserts every configured channel either produces scored frames or is explicitly reported as out of scope.

Section C · Source review findings — R-1 ... R-13

From the seven-part read-only recon of the checkout at beca6ff, 24 July 2026. These are ranked by release-blocking status × likelihood × effort. Full evidence with file and line citations lives in the recon reports; this is the register view.

MUST FIX BEFORE ANY PUBLIC RELEASE — ALL FOUR ARE LEGAL OR CLAIM-HONESTY ITEMS, NONE IS AN ENGINEERING DEFECT			
ID	FINDING	EVIDENCE AND IMPACT	ACTION & EFFORT
R-1	No LICENCE / NOTICE file	The repository root has no LICENCE, NOTICE or third-party file. Without an outbound licence, recipients have no legal grant — all rights reserved by default — and the LGPL database driver's notices are undisclosed. Blocks distribution outright.	Choose and add a licence; generate a notice file from a pinned lockfile. 1–2 days plus the decision.
R-2	Model acceptable-use unconfirmed	The licence audit flags model acceptable-use for government and surveillance applications as the leading open legal item. The weights — not the code — are the real exposure for a government camera product; shipping without written confirmation is a liability.	Obtain written confirmation for the specific checkpoints; confirm the unused vision models stay out of the production path. Legal-owned, elapsed time.
R-3	Auth-off default, fail-open gateway	Authentication defaults to off; with it off the agent gateway is bypassed entirely — no permission check, no approval, no audit — and API guards short-circuit. A misconfigured deployment silently runs with every control disabled.	Keep the secure-deployment gate mandatory; consider flipping the code default so the safe state is the default. 2–3 days or process-only.
R-4	Compliance claims exceed reality	The audit table carries hash-chain columns and a tool-ledger table exists, but neither is ever populated by code. Describing a "hash-chained tamper-evident audit log" to a security reviewer would be false; auditing rests on append-only rows with a fail-closed sink.	Either implement, or stop describing them and document what auditing actually provides. Hours (doc) / 1–2 weeks (build).

SHOULD FIX BEFORE BROAD ROLLOUT

ID	FINDING	EVIDENCE AND IMPACT	ACTION & EFFORT
R-5	Cross-tenant skills injection	Runtime skills are files in one global directory injected into every user's agent prompt, with attacker-authorable triggers, no versioning and no content audit. One holder of the prompt-management permission can inject standing instructions into other tenants' prompts. Only the state-change gates backstop it — and they constrain the agent's actions, not its words.	Scope skills per tenant, audit content on write, version them. 3–5 days , if multi-tenancy is real.
R-6	No continuous integration	No workflow files exist; the test suite and the docs drift gate run only when a person runs them. No automated safety net, so regressions reach releases unless someone remembers to run acceptance. The documentation refers to a CI that was never built.	Wire the existing suite and drift gate to run on push — the tooling is already CI-ready. 2–3 days .
R-7	Browser UI has no tests	16,500 lines of front-end JavaScript, zero executable tests, no harness. Every front-end change is unguarded — the riskiest place in the codebase to change. Section A of this register is the measured cost.	Stand up a smoke-level harness for the critical operator flows. ~1 week for a meaningful layer.
R-8	Silent vision batch loss	With the durable inference queue off — the default — an admission-gate timeout destroys a summary batch permanently and leaves no coverage-gap marker; a hard kill also loses in-flight batches. Against one capacity-one vision endpoint, timeouts are the expected steady state under load. Now field-confirmed as B-3.	Enable the shipped inference queue in production — spool, retry, reconcile. 1–2 days plus validation.
R-9	50-channel scaling unproven	Roughly 110 threads in one Python process at the 50-channel target, with no load evidence checked in. GIL contention, admission backlog and thread pressure are unquantified at scale. 0.8.5 declines to claim even its own 4–6 stream figure in advance.	Run the existing soak script at 50 channels and record the ceiling. 2–3 days .
R-10	Retention, orphans and disk-full	Retention runs only when writes happen — there is no scheduler — so an idle or disconnected system stops enforcing its own 90-day policy. A cap path deletes rows without their image files, leaking disk. There is no disk-free check anywhere; a full disk is an unhandled crash. On a sealed appliance, that is a truck roll.	Add a scheduled retention trigger, fix the orphan path, guard disk space. 2–4 days .

TRACK AND FIX OPPORTUNISTICALLY

ID	FINDING	EVIDENCE AND IMPACT	ACTION & EFFORT
R-11	Air-gap leaks	The stylesheet imports Google Fonts, and the model loaders lack offline flags. So an "air-gapped" product makes a call to Google — embarrassing rather than dangerous, with a cosmetic fallback — and could attempt a model-hub fetch on a cache miss. Everything else is genuinely call-free.	Self-host the three fonts; set the offline environment flags to make air-gap a code guarantee. ~½ day .
R-12	Stale orientation file	The file a new engineer — or an AI assistant — reads first still describes the predecessor image-search product rather than EVA AI. Onboarding therefore starts from a wrong map. Two commits claimed to update it and did not.	Rewrite to the current architecture. ~½ day .
R-13	Bus factor of one	One author across 264 commits; design rationale lives in the author's own notes and private remotes rather than in CI, comments or an accurate orientation file. Onboarding is estimated at one to two weeks for the Python core, with the UI and model path materially riskier.	R-6, R-7 and R-12 are the concrete mitigations; also normalise the three git identities. Ongoing .

The eight decisions that are yours, not engineering's

Everything else in this register has an obvious owner and a known fix shape. These do not — they are product judgements, and several of them get baked permanently into a sealed appliance image.

REF	DECISION	WHY IT CANNOT BE DECIDED BY WHOEVER WRITES THE CODE
R-1	Which licence does the product ship under?	And is the one unknown-licence dependency acceptable, or replaced? Blocks distribution entirely.
R-2	Who owns the model acceptable-use confirmation?	A legal question about the weights, not the code; needs a named owner and written evidence on file.
R-3	Flip the auth default, or mandate the deployment gate?	Both are defensible. One makes the safe state the default; the other keeps flexibility and relies on field discipline. A sealed appliance argues strongly for the first.
R-4	Build the audit hash chain, or correct the claim?	Hours versus one to two weeks — and the answer determines what sales and compliance material may say from today.
R-5	Is EVA AI multi-tenant in practice?	If not, several security findings downgrade immediately. If yes, the shared skills directory needs scoping before any multi-customer deployment.
B-2	Who owns alert severity policy?	What distinguishes info from critical, and does the model assign severity or does a policy layer map it? Currently every alert is HIGH, and no one owns changing that.
MF-9	What is the default probe threshold strategy?	A fixed floor demonstrably cannot work across concepts. Per-probe calibration at creation, negative prompts, or a visual score distribution — each is a different product.
MF-8	Move capture control into "operator", or rename the bundles?	Either fixes the surprise; they imply different permission models, and integrators will build against whichever ships.

What this register does not say

It does not say the product is in poor shape. Thirty-one findings across a source review, an instrumented benchmark and several days of adversarial hands-on testing is a *low* number for a codebase of this size, and the distribution is telling: no crashes, no data corruption, no security bypass found in testing, and no architectural defect. The runtime held up under everything thrown at it.

What it does say

The gap between this product and a shippable one is **defaults, policy and paperwork** — thresholds that match everything, one severity for every event, settings that do not apply, a missing licence file, and a claim that outruns the implementation. All of it is closable in weeks, and none of it requires re-architecting anything.

Sources. Manual QA findings MF-1...MF-12, living list, 24–25 July 2026 · Wave-1 end-to-end benchmark, run `2026-07-25-e2e8`, nine channels over 2.07 h at default settings, with the Feature Pack 1 and Part A experiments · Seven-part read-only source review at commit `beca6ff`, 24 July 2026 (inventory, architecture, data flow, agent, dependencies, development practice, management synthesis) · Luxriot EVA AI β 0.8.5 release notes, 27 July 2026, consulted for cross-references only. Every entry is traceable to its source report; file and line citations live there rather than here.